ЛЕКЦІЯ 1
БАЗОВІ ВИЗНАЧЕННЯ МАШИННОГО НАВЧАННЯ ТА НЕЙРОННИХ МЕРЕЖ

Мета: ознайомитися із концепцією інтелектуалізованих систем інформаційної безпеки та з'ясувати, чому класичні методи захисту не справляються із сучасними загрозами та яку роль у цьому відіграють машинне навчання та нейронні мережі.

ЗМІСТ

1. Терміни та визначення
2. Вступ
3. Машинне навчання та нейронні мережі у кібербезпеці
4. Датасети в задачах кібербезпеки
5. Датасет NSL-KDD
6. Класи та категорії подій у датасеті NSL-KDD
7. Висновки
8. Питання для самоконтролю

1. ТЕРМІНИ ТА ВИЗНАЧЕННЯ

Інформаційна безпека (ІБ) — комплекс заходів для захисту даних, комп'ютерних систем і мереж від несанкціонованого доступу, зміни або знищення.

Сигнатура (signature) — шаблон, який описує відому атаку, наприклад, комбінацію байтів або характерну поведінку шкідливого ПЗ.

IDS (Intrusion Detection System) — система виявлення вторгнень; аналізує події в мережі або системі, щоб помітити можливі атаки.

SIEM (Security Information and Event Management) — платформи для збору і аналізу логів подій з мереж і систем, щоб виявляти загрози.

UEBA (User and Entity Behavior Analytics) — системи аналізу поведінки користувачів і пристроїв для виявлення аномалій.

Машинне навчання (ML, Machine Learning) — галузь штучного інтелекту, в якій алгоритми навчаються на даних та роблять передбачення без прямого програмування всіх правил.

Нейронні мережі (NN, Neural Networks) — алгоритми штучного інтелекту, натхненні роботою мозку, які добре працюють зі складними багатовимірними даними.

2. ВСТУП

Упродовж останніх десятиліть інформаційна безпека розвивалася переважно навколо **правил і сигнатур**. Антивіруси, міжмережеві екрани, системи виявлення вторгнень працювали за принципом: якщо подія відповідає відомому шаблону — це атака.

Такий підхід був ефективним у часи, коли кількість типів атак була обмеженою, мережевий трафік був відносно простим, а обсяги даних дозволяли аналіз вручну або напівавтоматично.

Сьогодні ситуація кардинально змінилася. Сучасні інформаційні системи генерують величезні обсяги подій: мережеві потоки, журнали доступу, системні логи, телеметрію користувачів.

Серед проблеми сучасних систем варто виділити наступні:

- zero-day атаки — атаки, для яких ще немає сигнатур або виправлень, їх неможливо виявити класичними методами;
- шифрований трафік — сучасні мережі часто використовують HTTPS, TLS, VPN, що ускладнює аналіз пакетів;
- поліморфні атаки — атаки, які змінюють свою форму, щоб уникнути виявлення сигнатурами;
- великий обсяг даних — мережі та сервери генерують мільйони подій на день; аналіз вручну неможливий;
- помилкові спрацювання (False Positives) — нормальна активність класифікується як атака;
- пропуски (False Negatives) — реальні атаки залишаються непоміченими.

Тому потрібні системи, які вміють виявляти закономірності та відхилення від нормальної поведінки. У відповідь на ці виклики почали з'являтися інтелектуалізовані системи інформаційної безпеки.

Інтелектуалізовані системи інформаційної безпеки — це програмно-апаратні системи захисту, які використовують методи штучного інтелекту, машинного навчання та нейронних мереж для автоматичного виявлення, аналізу та прогнозування кіберзагроз на основі закономірностей у даних, а не лише заздалегідь визначених правил або сигнатур.

Такі системи застосовуються в системах виявлення вторгнень (IDS), SIEM-платформах, системах аналізу поведінки користувачів (UEBA) та засобах виявлення шкідливого ПЗ.

3. МАШИННЕ НАВЧАННЯ ТА НЕЙРОННІ МЕРЕЖІ В КІБЕРБЕЗПЕЦІ

Машинне навчання (Machine Learning, ML) — галузь штучного інтелекту, що дозволяє комп'ютерним системам автоматично виявляти закономірності у даних та робити прогнозування без явного програмування правил.

Машинне навчання є методологією, до складу якої входять різні алгоритми та методи, серед яких варто виділити нейронні мережі (Neural Networks, NN) — клас алгоритмів ML, натхненний роботою мозку, який добре справляється зі складними, багатовимірними даними.

За своєю структурою нейронні мережі є математичною моделлю, яка складається з певної кількості так званих «нейронів» та зв'язків між ними, що мають різні значення коефіцієнтів впливу на результат роботи системи. Ці коефіцієнти прийнято називати «вагами», а налаштування їхніх значень і є основним методом навчання нейронної мережі.

В кібербезпеці метою нейронних мереж є знаходження закономірностей між ознаками та видами зловмисних дій щодо конфіденційності, цілісності або доступності даних. Після навчання модель буде здатна працювати з новими даними, які раніше не використовувалися для її навчання.

Нейронні мережі є ефективним інструментом машинного навчання, коли дані складні та багатовимірні із приховані нелінійні залежності, а також у випадках, якщо класичні методи не дають достатньої якості. Разом з тим нейронні мережі важко інтерпретувати, складно контролювати та легко вводяться в оману. Тому їх використання в інформаційній безпеці вимагає особливої обережності.

Таким чином, ключовою особливістю машинного навчання та нейронних мереж є пошук закономірності в даних. Машинне навчання дозволяє системі навчатися на історичних даних, знаходити закономірності, які важко формалізувати правилами та адаптуватися до змін середовища. Однак важливо розуміти, що машинне навчання не "розуміє" атаку, а лише знаходить статистичні відмінності.

Це призводить до двох ключових проблем: легітимна активність може визначитися як атака (так зване явище false positive), або ж навпаки, атака залишається непоміченою (false negative). У кібербезпеці ці помилки можуть мати серйозні наслідки.

4. ДАТАСЕТИ В ЗАДАЧАХ КІБЕРБЕЗПЕКИ

Нейронні мережі в якості основи для аналізу та закономірностей використовують набір даних, що називається датасетом (dataset). Датасет (dataset) — це структурований набір даних, зібраних для аналізу, навчання або тестування алгоритмів обробки інформації, зокрема методів машинного навчання та штучного інтелекту.

У контексті кібербезпеки датасет зазвичай містить інформацію про мережеві з'єднання, характеристики трафіку, параметри поведінки користувачів або систем, а також мітки класів, що вказують, чи є подія нормальною або атакою.

Таким чином, датасет — це велика таблиця, де кожен рядок описує одну подію**,** а кожна колонка — її характеристику**.**

Датасети використовуються для:

- навчання систем виявлення атак (IDS): модель аналізує дані і навчається відрізняти нормальну поведінку від шкідливої;
- тестування ефективності алгоритмів: перевіряється, наскільки добре система знаходить атаки;
- порівняння методів: один і той самий датасет дозволяє порівнювати різні підходи.

Типовий датасет складається з рядків (samples) та колонок (features)**.** Рядки містять записи про окрему **подію**, наприклад мережеве з'єднання, сеанс чи спробу доступу. Кожна колонка містить дані про ту чи іншу **ознаку**, що описує певний аспект події, наприклад тривалість з'єднання, кількість переданих байтів, тип протоколу, кількість помилок тощо.

В контексті задач кіберзбезпеки остання колонка датасету, як правило, містить мітку класу (label), що вказує, чи була подія нормальною мережевою активністю або зловмисною дією (атакою).

Атака (attack) – будь-яка зловмисна дія, спрямована на порушення роботи системи, доступу до даних або конфіденційності користувачів.

Існує декілька способів отримання датасетів:

- реальний мережевий трафік;
- контрольовані експерименти, в яких створюється тестова мережа та імітуються нормальні та зловмисні події;
- штучний синтез, який використовується переважно в освітніх цілях.

При створенні датасету для подальшого навчання нейронної мережі відбуваються наступні процеси:

1. Протоколювання мережевих подій (logging):

1.1. Сервери, маршрутизатори або спеціальні системи IDS/Firewall фіксують всі події мережі.

1.2. Кожен пакет або сесія записується у лог: IP-адреса, порти, обсяг даних, тривалість, стан з'єднання тощо.

2. Анонімізація та фільтрація

2.1. Для навчальних датасетів часто приховують реальні IP-адреси або особисту інформацію.

2.2. Видаляються непотрібні колонки і залишають ті, які важливі для навчання моделей.

3. Міткування (Labeling)

3.1. Експерти аналізують події і визначають, яка з них нормальна, а яка є зловмисною.

3.2. Іноді атаки запускають штучно в лабораторії, щоб отримати підписані дані (наприклад, Flood, Scan).

4. Формування таблиці

4.1. Кожна сесія стає рядком, колонки — ознаки, остання колонка — міткою.

4.2. Результат — готовий датасет, який можна передавати в ML-моделі для навчання та тестування.

Таким чином, датасет в кібербезпеці — це історія подій, яка дозволяє моделі навчитися відрізняти нормальні сесії від зловмисних. Водночас, важливо розуміти, що датасет не містить всіх можливих атак, а лише відображає ті події, які були зафіксовані і підписані.

5. ДАТАСЕТ NSL-KDD

Переважно датасети мають обмежений доступ, так як можуть містити елементи комерційної, державної чи військової таємниці. Водночас, у відкритому доступі існують датасетів, які використовуються у сфері вивчення машинного навчання в кібербезпеці. Одним із таких датасетів є NSL-KDD.

NSL-KDD — це вдосконалена версія датасету **KDD Cup 1999**, створена для досліджень у сфері систем виявлення вторгнень (IDS).

Його основні властивості:

- кожен рядок містить запис про одне мережеве з'єднання;
- містить 41 ознаку та мітку класу події;
- широко використовується в навчанні та наукових роботах.

Попри широкий вжиток у вивченні нейронних мереж, варто розуміти, що датасет NSL-KDD містить лише зловмисні мережеві події, відомі на момент його створення у 1999 році. Водночас, ці зловмисні дії є базовими для вивчення сучасних мережевих загроз у сфері кібербезпеки.

Ознаки подій у датасеті NSL KDD поділяються на кілька груп:

1. Базові мережеві ознаки:
    - duration — тривалість з'єднання;
    - protocol_type — тип протоколу (TCP, UDP, ICMP);
    - service — мережевий сервіс;
    - flag — стан TCP-з'єднання.
2. Ознаки контенту:
    - кількість помилкових логінів;
    - спроби отримання прав адміністратора мережі;
    - підозрілі дії користувача.
3. Ознаки на основі трафіку:
    - кількість з'єднань за короткий період;
    - відсоток помилкових відповідей;
    - повторюваність сервісів.

Мітка класу (label) — це категорія, до якої належить певна подія. У датасеті NSL-KDD такими мітками є:

- normal — нормальна активність;
- назви атак — різні типи зловмисної поведінки.

Класи використовуються як ціль навчання (target) для нейронної мережі а також в якості еталону для перевірки точності.

6. КЛАСИ ТА КАТЕГОРІЇ МЕРЕЖЕВИХ ПОДІЙ У ДАТАСЕТІ NSL-KDD

У датасеті NSL-KDD окремі класи подій об'єднуються у великі категорії для спрощення задачі навчання, зменшення кількості класів, кращої інтерпретації результатів та реалістичного моделювання загроз.

Основними категоріями подій у датасеті NSL-KDD є наступні:

1. Normal — описує легітимну поведінку системи, тобто звичайні з'єднання, коректна робота сервісів та відсутність ознак зловмисної дії. Цей клас є базовим еталоном, з яким порівнюються всі інші.
2. Denial of Service (DoS, *англ.* відмова в обслуговуванні) — це атака, метою якої є виведення системи з ладу шляхом перевантаження ресурсів сервера. Типові ознаки:
   - дуже велика кількість запитів;
   - різке зростання трафіку;
   - високі значення обсягів інформації запитів від клієнта та відповіді сервера.
3. Probe — сканування системи з метою виявлення відкритих портів, активних сервісів та потенційних вразливостей. Характерні риси:
   - велика кількість коротких з'єднань;
   - звернення до різних сервісів;
   - низький обсяг переданих даних.
4. Remote to Local (R2L, *англ.* з віддаленого до локального) — це спроба отримати локальний доступ до системи ззовні. Особливості:
   - велика кількість спроб авторизації;
   - спроби підбору паролів;
   - використання слабких сервісів.
5. User to Root, (U2R, *англ.* від користувача до адміністратора) — це спроба підвищити привілеї з рівня звичайного користувача до адміністратора (root). Характерні ознаки:
   - використання вразливостей програмного забезпечення сервера;
   - запуск шкідливого коду.

Приклади класів, що належать до вищезгаданих категорій, а також їхній опис, подані у таблиці 1.

Категорія	Класи	Опис
Normal	normal	Нормальна активність мережі, без загроз
DoS (Denial of Service)	neptune, smurf, back, teardrop, pod, land	Атаки на відмову обслуговування: перевантажують сервер або мережу
Probe	satan, ipsweep, portsweep, nmap	Розвідка мережі, сканування хостів і портів для пошуку вразливостей
R2L (Remote to Local)	warezclient, warezmaster, guess_passwd, imap, ftp_write, phf, multihop, spy, perl	Віддалене проникнення: намагання отримати доступ до системи без прав
U2R (User to Root)	buffer_overflow, rootkit, loadmodule	Підвищення привілеїв та отримання прав адміністратора

Табл. 1. Категорії подій, прикладі класів подій та їхній опис

7. ВИСНОВКИ

1. Інтелектуалізовані системи інформаційної безпеки — необхідний інструмент сучасної кібербезпеки, що допомагають обробляти та аналізувати великі обсяги мережевих даних.
2. Машинне навчання як методологічна галузь штучного інтелекту досліджує методи та алгоритми нейронних мереж.
3. Нейронні мережі в кібербезпеці застосовуються для аналізу набору даних мережевих подій, виявлення закономірностей та створення систем виявлення зловмисних дій.
4. Датасети є структурованим набором даних, що використовуються для навчання нейронних мереж.
5. В кібербезпеці датасети містять дані щодо класів та категорій мережевих подій, як нормальних так і зловмисних.
6. Класичним датасетом, що використовується для вивчення галузі нейронних мереж та їхнього навчання є NSL-KDD, що містить такі категорії подій як Normal, DoS, Probe, R2L та U2R.

8. ПИТАННЯ ДЛЯ САМОКОНТРОЛЮ

1. Що таке інформаційна безпека?
2. Що таке сигнатура атаки?
3. Розшифруйте та поясніть призначення IDS, SIEM, UEBA.
4. Що таке машинне навчання?
5. Що таке нейронна мережа?
6. Що таке датасет?
7. Що таке label (мітка класу) у датасеті?
8. Чому сигнатурні методи захисту перестали бути ефективними?
9. Що таке zero-day атака і чому її складно виявити?
10. У чому різниця між false positive та false negative?
11. Чому датасет не може містити всі можливі атаки?
12. Які типи даних можуть входити до датасету кібербезпеки?
13. Як нейронна мережа використовує датасет для навчання?
14. Наведіть приклади ознак (features) у мережевому датасеті.
15. Що таке NSL-KDD і для чого він використовується?
16. Назвіть основні категорії подій у датасеті NSL-KDD.
17. Чому машинне навчання краще підходить для сучасної кібербезпеки, ніж сигнатурні методи?
18. Які ризики використання нейронних мереж у кібербезпеці?
19. Чому велика кількість даних є одночасно і проблемою, і перевагою?
20. Чому категоризація атак спрощує навчання моделі?
21. Чи актуальний NSL-KDD сьогодні, враховуючи що він базується на даних 1999 року?